Coincheck NEM Theft, January 2018

Cryptocurrency exchange hack investigation: key findings and recommendations

Kshitij Randhire | Independent research project

What happened

526.3M

XEM left Coincheck's wallet in 11 transfers (my blockchain count)

~523M

XEM was Coincheck's own figure; about 58 billion yen at the time

260,000

customers affected; more than 46 billion yen refund pledged

- The XEM sat in an internet-connected hot wallet that one key could empty.
- Coincheck noticed at 11:25 on 26 January (case study), over eight hours after its stated start (Reuters).

Sources: Reuters, BBC, ScienceDirect case study, blockchain data collected 28 Sep 2026 (EVD-001, 004, 011)

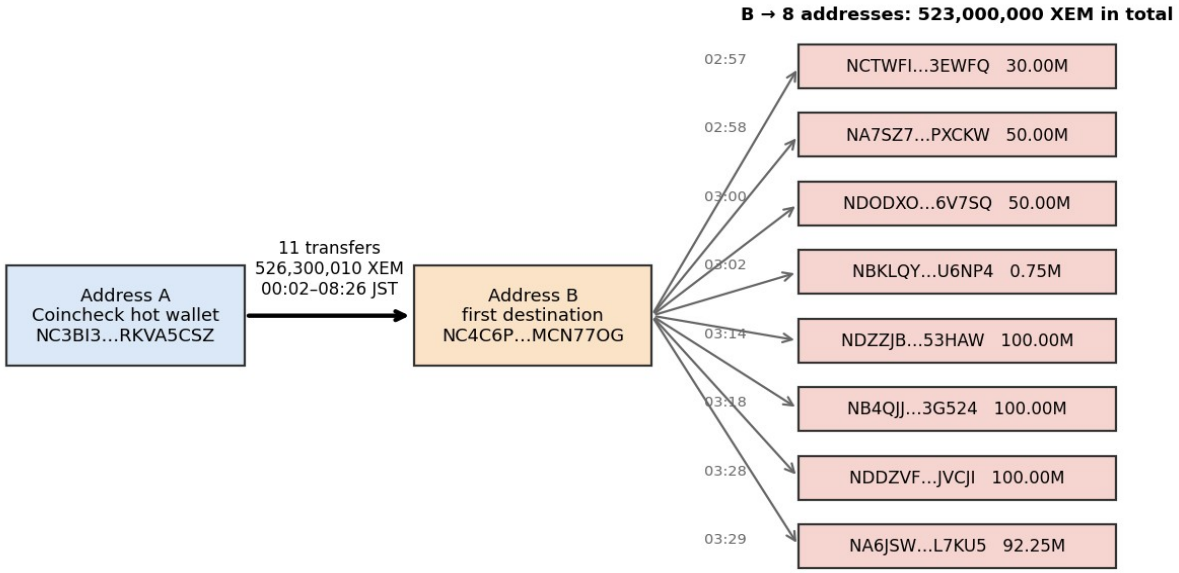
Limits: one public node, one hop traced, and the two discrepancy explanations are interpretations (see slide 7).

Timeline (26 January 2018, JST)

Time	Event	Basis
00:02	First transfer out of Coincheck's wallet: 10 XEM test	Blockchain
00:04 to 00:21	523,000,000 XEM moved to a new address (Address B)	Blockchain
02:57 to 03:29	Address B splits exactly 523,000,000 XEM across 8 addresses	Blockchain
03:35 to 08:26	Three more transfers, 3.3M XEM in total	Blockchain
11:25	Coincheck notices the drop and freezes all but Bitcoin	Case study, BBC
30 Jan	FSA business improvement order discussed at press conference	FSA transcript

All times use the corrected NEM epoch (00:06:25 UTC). Details: Incident Report, Section 3

How the funds moved



Times are JST on 26 Jan 2018. Only one hop beyond Address B was traced.

- Address A to B: 11 transfers, 526,300,010 XEM.
- B to 8 new addresses: exactly 523,000,000 XEM in 33 minutes.
- I traced one hop. Where the coins went next is not established.

Source: NIS1 node data, EVD-017 to 019. Method and hashes: Evidence Portfolio

Two gaps between the blockchain and the reports

1. The missing 3.3M XEM

Coincheck said ~523M. The chain shows 526.3M. The first eight transfers add up to 523,000,010 and the last three to exactly 3,300,000. My reading: Coincheck's figure matches the first eight. Why the last three are not reflected is unknown.

2. When it started

Coincheck gave 02:57. The first transfer out of its wallet is at 00:02. The 02:57 matches the first onward transfer from Address B. My reading: the company described when the coins began to be spread out, which makes the true detection gap about 11 h 23 min.

Both are my interpretations. The arithmetic is confirmed; I found no Coincheck confirmation of the explanations.

Why it was possible, and what it cost

- Single key: all 11 transfers were plain transfers signed by one key, with no co-signatures.
- Hot wallet: the COO and BBC describe the XEM as held online, not in cold storage.
- Slow detection: about 11 hours from the first transfer to discovery.
- Thin resources: the president cited technical difficulties and a staff shortage.

Not established: how the attacker got access, who they were, and whether customer data was exposed.

Sources: EVD-001, 004, 011. Attack vector is marked Unknown in the Incident Report (one case study reports malware on a company terminal; unconfirmed).

What this analysis cannot tell you

1 node

All blockchain data came from one public NIS1 node and has not yet been cross-checked

1 hop

Funds are traced from A to B to eight addresses. Where they went next is not traced

2 readings

The two discrepancy explanations are my interpretations, not confirmed facts

- No internal Coincheck logs, disk images, memory dumps or malware samples are public.
- How the attacker got in, who they were and whether customer data was exposed remain unknown.

Details: Incident Report Sections 7.7 and 11; Evidence Portfolio Section 6.

Recommendations

Immediate

- Suspend withdrawals for the affected asset
- Share destination addresses with exchanges and the NEM Foundation
- Treat the signing key as compromised
- Preserve logs and images, tell regulators and customers

Long term

- Multiple signatures on every hot wallet
- Cold storage for most funds, with a hot-wallet cap
- Real-time outflow alerts and daily reconciliation
- Key management review, annual audit, tested response plan

Full plan with risk ratings: Mitigation Plan. Limits: public sources only, one node, one hop traced.